David
Ramin
BTS SIO 2

23/09/25

Bloc 3 - Cybersécurité

Activité 2 : Vulnérabilités liées à l'authentification et à la gestion des sessions

Table des matière :

- ➢ Objectifs de l’activités
- ➢Travail à faire 1 : énumération des logins

Introduction sur l’objectif à réaliser

Trois défis sont proposés pour illustrer la sécurisation de l’authentification et des sessions :

- l’énumération des logins : il s’agit d’énumérer des logins valides à partir d’un dictionnaire ;
- une attaque par force brute sur un login valide : l’attaquant étant certain qu’un login est valide,
il peut tenter une force brute sur le mot de passe ;
- un vol de session à l’aide d’un cookie d’identification prévisible afin de s’identifier à l’aide du
compte d’un autre utilisateur sans connaître son login et son mot de passe.

➢Travail à faire 1 : énumération des logins

Le but de cette première série de questions est d'étudier le comportement de l'application en mode
non sécurisé afin de lancer l'attaque visant à énumérer des logins valides.

Etape 1

Dans l'étape 1, avec l'extension Wsdler nous avons pu avoir un aperçu des opérations en accédant au Parse WSDL. Ici, getUser nous intéressait le plus pour réaliser notre étape.

Observant le code de getUser, la balise username contient une valeur par défaut correspondant à un login qui n'existe pas dans la liste des logins valides des comptes déjà existants (gero et).

En suivant, plus précisément les indications j'ai cliquer sur Send to Repeater. Send to Repeater ajoute sur Burpsuite un sous-onglet à notre requête.

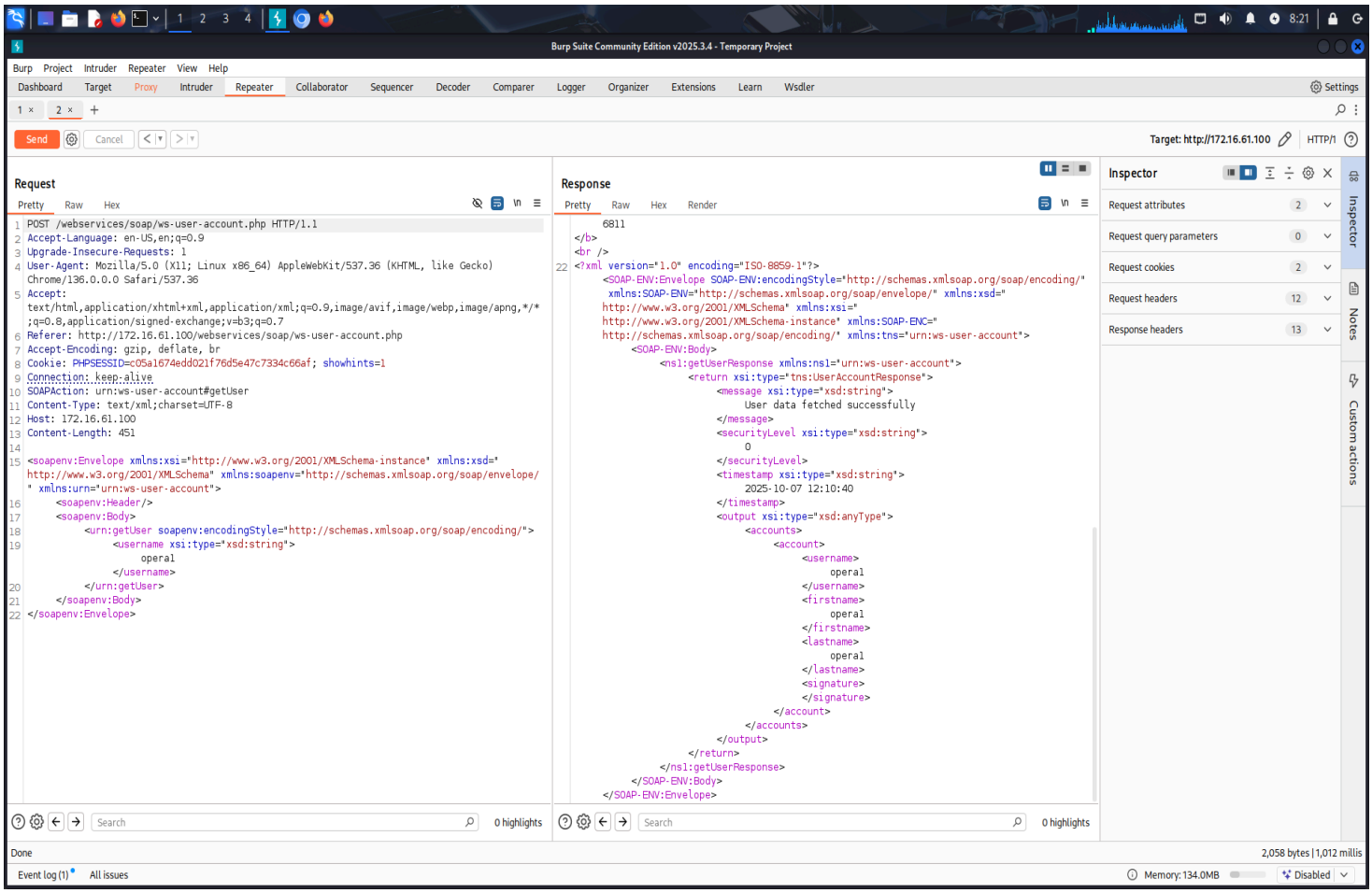
Send to Comparer de BurpSuite s'enrichit de notre première réponse correspondant à un login inexistant. En soit, il répond à la requête de Send to Repeater

Etape 2

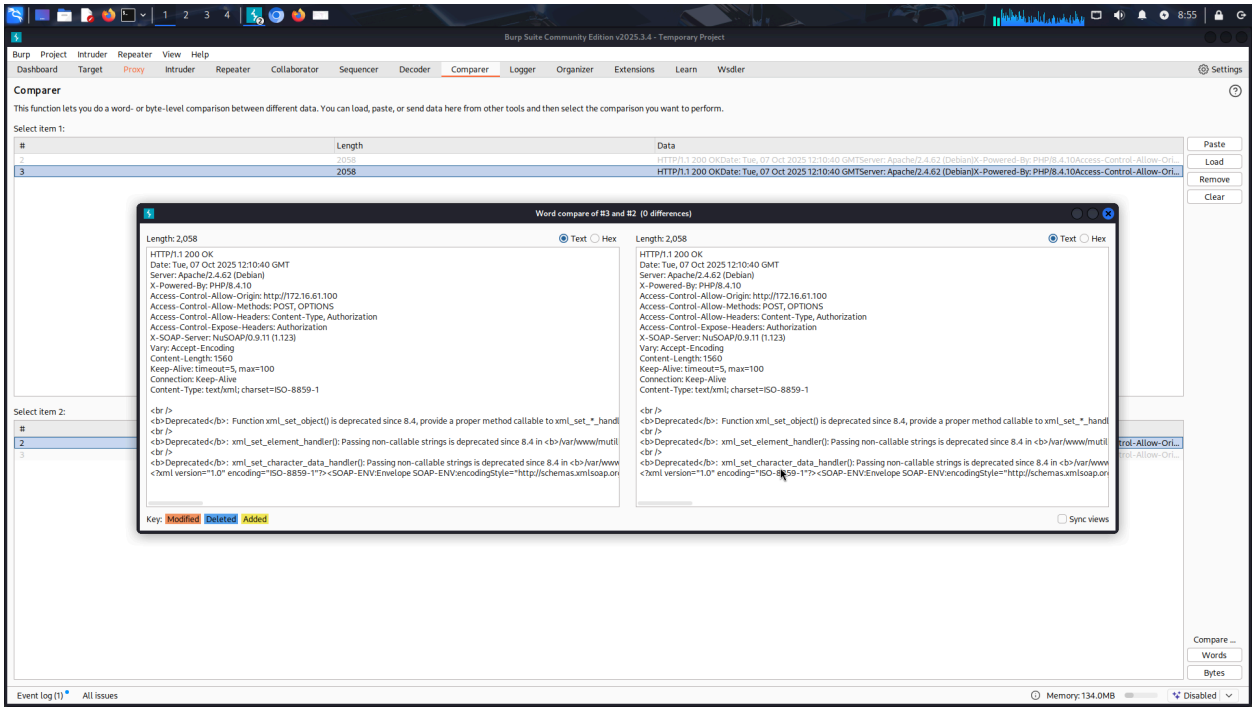
Dans l'étape 2, nous devons créer plusieurs utilisateurs dans Please Register Here. Dans cette étape, on devait en créer 2.

Ensuite le principe dans cette étape, reste le même que l’étape 1 en suivant ses instructions :
OWASP 2017 => A2 : Broken Authentication and Session Management => Username Enumeration
=> Lookup User (SOAP Web Service).
Positionner ensuite le proxy à intercept on, puis cliquer sur le lien View the WSDL.
Comme précédemment, faire un clic droit dans la fenêtre de capture du proxy et cliquer sur Parse
WSDL. Puis, dans l’onglet Wsdler de BurpSuite, cliquer sur getUser et envoyer la requête au répéteur (Send to Repeater) par un clic droit.

Après cela, dans cette interface, on appuie sur Send et nous observons la réponse de requête. J'ai remplacé gero et par mon username que j'ai créé : opera1 et ça me l'a renvoyé.



Ensuite, dans l’onglet Comparer pour remarquer des différences de messages on clique sur words. Malheureusement, il n’ y a pas de différence mais pour la signification du tableau : La fenêtre de gauche correspond à la réponse obtenue en cas de login inexistant. Celle de droite en cas de login existant.



Pour conclure, l'étape 2 m’a beaucoup enrichi pour la création de login et le fait que le résultat de toutes ces manipulations nous renvoie dans la fenêtre réponse notre saisie username, password….